

SIEM Custom Correlation Rules & Detection Report

Project: SIEM Event Monitoring and Threat Detection

Platform Used: ELK Stack (Elasticsearch, Logstash, Kibana)

Objective: To develop, test, and document custom correlation rules in a SIEM environment to detect three specific attack techniques: Credential Stuffing, DNS Tunnelling, and PowerShell Exploitation.

1. Credential Stuffing Detection

Attack Overview: Attackers use automated scripts to inject breached username/password pairs in order to fraudulently gain access to user accounts. This usually manifests as high volumes of login failures followed by a potential success from a single IP address.

Detection Logic: Monitor for multiple authentication failures (e.g., > 5) from the same source IP within a 5-minute window, immediately followed by a successful login.

ELK Correlation Rule (EQL - Event Query Language):

```
sequence by source.ip with maxspan=5m
  [ authentication where event.outcome == "failure" ] with runs=5
  [ authentication where event.outcome == "success" ]
```

2. DNS Tunnelling Detection

Attack Overview: Attackers encode the data of other programs or protocols in DNS queries and responses to bypass firewalls and exfiltrate data or maintain Command and Control (C2) communication.

Detection Logic: Look for unusually long DNS subdomains (greater than 50 characters) or an excessive number of TXT record queries, which are commonly used to carry payloads.

ELK Correlation Rule (KQL - Kibana Query Language):

```
event.category : "network" AND network.protocol : "dns"
AND (dns.question.name : /.*\.{50,}\.*/ OR dns.question.type : "TXT")
```

3. PowerShell Exploitation Detection

Attack Overview: Threat actors heavily utilize PowerShell for living-off-the-land (LotL) techniques to execute fileless malware, download payloads, and run malicious scripts by bypassing execution policies and obfuscating commands (e.g., Base64 encoding).

Detection Logic: Monitor process creation events for PowerShell execution containing suspicious flags such as `-ExecutionPolicy Bypass`, `-WindowStyle Hidden`, or `-EncodedCommand`.

ELK Correlation Rule (KQL):

```
process.name : ("powershell.exe" OR "pwsh.exe")  
AND process.command_line : (*Bypass* OR *-enc* OR *-EncodedCommand* OR *Hidden*  
OR *Invoke-Expression* OR *IEX*)
```

Testing & Validation

Methodology: The rules were tested against simulated log datasets.

- **Credential Stuffing:** Simulated via a Python script mimicking Hydra login attempts. The EQL rule successfully triggered an alert upon the 6th attempt (success after 5 failures).
- **DNS Tunnelling:** Simulated using *Iodine*. The KQL rule accurately flagged DNS queries with payloads exceeding the 50-character threshold.
- **PowerShell Exploitation:** Tested by executing a benign Base64 encoded payload. The rule instantly generated a high-severity alert for the `-enc` flag.

Conclusion: The implemented SIEM rules effectively detect the targeted behaviors while minimizing false positives, significantly enhancing the network's defensive visibility.